

LOGGING AND MONITORING POLICY

Version 1.0

Revision Date: August 18, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Logging and Monitoring Policy
Document ID	POL-LOG-001
Current Version	1.0
Approved Date	August 18, 2026
Approved By	Information Security Steering Committee
Effective Date	August 18, 2026
Next Review Date	August 18, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Policy is authorized by the Information Security Policy (POL-ISP-001) and supports the SOC 2 Trust Services Criteria CC2.1, CC3.3, CC4.1, CC7.2, CC7.3 and CC8.1, HIPAA Security Rule 45 CFR §164.308(a)(1)(ii)(D) and §164.312(b), and GDPR Articles 5, 6 and 32. It covers the systems the Company runs — AWS, GitHub, Google Workspace and approved AI services — and does not extend to personally owned devices.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE5

2 SCOPE5

3 ROLES AND DEFINITIONS.....5

4 TERMINOLOGY5

5 WHAT IS LOGGED6

6 PROTECTION AND RETENTION7

7 ALERTING7

8 REVIEW7

9 LOGGING FOR AI AND AGENT ACTIVITY8

10 PERSONAL DEVICES8

11 RECORDS8

12 ENFORCEMENT.....9

13 EXCEPTIONS.....9

14 REFERENCE.....9

1 DOCUMENT POLICY HISTORY9

1 Overview and Purpose

PromptHalo Technologies (“the Company”) needs to be able to answer three questions after the fact: what happened, when, and who did it. This Policy says what is logged to make that possible, how those records are protected, and what is looked at.

It is scoped to the systems the Company controls — AWS, GitHub, Google Workspace and the approved AI services. Almost everyone works from their own laptop, and this Policy does not reach those devices. What is logged is what the Company's own accounts and services emit.

The design point is that logging should be switched on once and then largely look after itself. Where a choice exists between a native platform feature and a product to buy, the native feature is used.

2 Scope

This Policy applies to Company-controlled systems: AWS accounts and workloads, the GitHub organisation, Google Workspace, the password manager, and any AI service reached through a Company account. It applies to agents and automations that act on those systems.

It does not apply to personally owned laptops or phones. The Company operates no agent on them and collects nothing from them, as stated in the Acceptable Use Policy.

Requirements apply so far as they are lawful where each person works. Where this Policy calls for a tool, the least costly option that satisfies the requirement is used.

3 Roles and Definitions

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]
4. The Accountable Party performs the monthly alert review and holds its record. Where the same person both operates the systems and reviews the alerts, that is recorded as a concentration in the Annual Control Environment Assessment rather than left unstated. [SOC 2: CC4.1, CC1.3]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **Agent** — an autonomous or semi-autonomous software component that takes actions using tools or system interfaces.
3. **Alert** — an automated notification raised when logged activity matches a detection rule.

4. **Audit log** — a system-generated record of an event, retained so that activity can be reconstructed afterwards.
5. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
6. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
7. **Disposition** — the recorded conclusion of triage, including the conclusion that an alert was not an incident.
8. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this policy to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. The Committee's composition is reviewed as the Company grows, and additional members are appointed when an oversight member independent of security operations becomes available. [SOC 2: CC1.2, CC1.3]
9. **Log source** — a system or service that emits audit records into a Company log destination.
10. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
11. **Population** — the complete set of instances of an event or control execution in a period, from which a sample can be drawn.
12. **Security Officer** — the individual accountable for day-to-day operation of the security program.

5 What Is Logged

Four platforms emit almost everything that matters, and each logs natively once switched on.

1. **AWS:** CloudTrail management events in every account and region, and CloudTrail data events for buckets holding client information. This is the record of who did what in the cloud estate. [SOC 2: CC7.2 · HIPAA §164.312(b)]
2. **Google Workspace:** admin, login and OAuth grant audit logs, which is where account compromise and unapproved application access show up first. [SOC 2: CC7.2, CC6.1]
3. **GitHub:** organisation and repository audit logs, covering access changes, branch protection changes and secret-scanning alerts. [SOC 2: CC7.2, CC8.1]
4. **Application and agent activity in the product,** where the Company's own code writes the record. [SOC 2: CC7.2, CC2.1]
5. Each record carries enough to establish what happened, when, from where, and the identity involved. A record that cannot answer those four questions is not sufficient, and that is the test rather than a prescribed field list. [SOC 2: CC7.2-01, CC2.1]

6. Secrets, credentials, full authentication tokens and client information are not written into logs. Where they might appear, the field is redacted at source. [SOC 2: CC6.7 · C1.1]

6 Protection and Retention

1. Logs are retained for at least thirteen months, with the most recent ninety days available for immediate query. Thirteen months is chosen so that a twelve-month observation period is fully covered with margin. [SOC 2: CC7.2, CC4.1]
2. Log storage is separated from the accounts that generate the logs, so that someone who compromises a workload cannot erase the record of it. In AWS this is a dedicated logging destination with object lock or an equivalent write-once setting. [SOC 2: CC7.2, CC6.1]
3. Access to logs is restricted to those who need it, and changes to logging configuration are themselves logged. Turning logging off is an event worth seeing. [SOC 2: CC7.2, CC6.3]
4. Where a platform's own retention is shorter than thirteen months, records are exported to the logging destination before they expire. Google Workspace and GitHub both require this. [SOC 2: CC7.2]

7 Alerting

Alerting is deliberately narrow. A short list that gets read beats a long list that gets muted, and at the Company's size every alert lands with one person.

1. Alerts are configured for a small set of high-signal events: root or organisation-level account use, changes to logging configuration, new administrative grants in Workspace or GitHub, unapproved OAuth application grants, and secret-scanning findings. [SOC 2: CC7.2, CC7.3]
2. Alerts go to security@prompthalo.com and are triaged when they arrive. Anything suspected to be an incident is escalated under the Incident Response Policy. [SOC 2: CC7.3, CC7.2]
3. Every alert receives a recorded disposition, including the conclusion that it was not an incident. The complete population of alerts for a period, with dispositions, is what a service auditor samples — a list of only the interesting ones is not a population. [SOC 2: CC7.3, CC2.1]
4. Alerting coverage is reviewed annually against the events above, and adjusted where the estate has changed. Adding an alert that fires constantly is a coverage problem, not a success. [SOC 2: CC7.2, CC4.1]

8 Review

1. Alert dispositions for production are reviewed monthly. The record shows the date, who reviewed, the period covered and the conclusion. Where no alerts arose in the month, that is recorded and the review is complete. [SOC 2: CC4.1, CC7.2]
2. The review takes minutes when there is nothing to see, and that is the point: the evidence is that it happened every month, not that it took long. Twelve records a year is what a Type II sample needs, and a missed month cannot be recovered afterwards. [SOC 2: CC4.1]

3. Logging that produces no reviewed disposition is not a control. Where alerting is on but nothing is reviewed, that is recorded as a deficiency rather than reported as coverage. [SOC 2: CC4.1, CC2.1]
4. Privileged access held inside customer environments is reviewed at the same monthly sitting, because standing access to a client's estate is the Company's largest insider risk. [SOC 2: CC3.3, CC6.3]

9 Logging for AI and Agent Activity

Agents act on Company systems under their own identities. Their activity is logged so that behaviour can be reconstructed, which is what makes an agent reviewable rather than merely trusted.

1. Agent activity is logged with enough context to reconstruct what happened: the triggering input, the tools invoked, the parameters used, the actions taken and the outcome. [SOC 2: CC7.2, CC2.1]
2. Each agent runs under its own identity rather than a person's credentials, so that its actions are attributable in the same logs as anyone else's. [SOC 2: CC6.1, CC7.2]
3. Prompts, tool definitions, retrieval configuration, guardrails and model versions are changed through the same approval path as code, and those changes are logged. What the model was and what it was told are part of reconstructing what it did. [SOC 2: CC8.1, CC7.2]
4. Client information is not written into prompt or completion logs. Where an interaction has to be retained for debugging, it is redacted first. [SOC 2: CC6.7 · C1.1]

10 Personal Devices

1. The Company logs activity in its own systems, not on anyone's laptop. It operates no logging agent on personally owned devices and collects nothing from them. [SOC 2: CC7.2 · GDPR Art. 5(1)(c)]
2. Because work happens in Company cloud services, the account-side record is sufficient: a person acting on client information does so through Workspace, AWS or GitHub, and that is where the record is written. [SOC 2: CC7.2, CC6.1]
3. What the Company logs, and what it does not collect, is stated in the Acceptable Use Policy and acknowledged annually. Monitoring that is not disclosed is neither lawful nor trusted. [SOC 2: CC2.2 · GDPR Art. 13]

11 Records

1. The logging configuration and the list of log sources. [SOC 2: CC2.1]
2. Monthly alert disposition reviews, twelve a year, including nil months. [SOC 2: CC4.1]
3. The complete population of alerts for the period with each disposition. [SOC 2: CC7.3]
4. The annual alerting coverage review. [SOC 2: CC7.2, CC4.1]
5. Retention settings evidencing thirteen months, and the write-once configuration on the logging destination. [SOC 2: CC7.2]

12 Enforcement

1. Disabling logging, deleting audit records, or acting to avoid attribution is handled under the Code of Conduct, with the finding, the decision and the reason recorded. [SOC 2: CC1.1, CC1.5]

13 Exceptions

Where a requirement of this Policy cannot be met — a platform that does not emit a needed record, or a retention setting a plan does not support — the position is recorded by the Accountable Party with the compensating measure and a review date, rather than left silent. Where no exceptions are in force, that is recorded affirmatively at the annual review.

14 Reference

1. SOC 2 Trust Services Criteria, Security category [CC2.1, CC3.3, CC4.1, CC7.2, CC7.3, CC8.1]
2. POL-ISP-001 Information Security Policy [SOC 2: CC5.3]
3. POL-IRP-001 Incident Response Policy [SOC 2: CC7.3]
4. POL-AC-001 Access Control Policy [SOC 2: CC6.1, CC6.3]
5. POL-AUP-001 Acceptable Use Policy [SOC 2: CC7.2]
6. POL-CM-001 Change Management Policy [SOC 2: CC8.1]
7. POL-RSK-001 Risk Management Policy [SOC 2: CC3.3]
8. HIPAA Security Rule, 45 CFR §164.308(a)(1)(ii)(D) and §164.312(b)
9. EU General Data Protection Regulation, Articles 5, 6 and 32

1 DOCUMENT POLICY HISTORY

Version	Date	Description
1.0	August 18, 2026	Initial policy release